TATA KELOLA & PENGENDALIAN INTERNAL (INTERNAL CONTROL)

PANDUAN & KEBIJAKAN MANAJEMEN USER LEVEL

Pedoman Standar Hak Akses, Segregation of Duties (SoD), dan Implementasi Keamanan Database Row Level Security (RLS) pada Sistem Akuntansi Perusahaan Dagang

NAMA DOKUMEN
User Authority & Access Management Guide

STANDAR KEPATUHAN
COSO Internal Control & SAK Indonesia

TEKNOLOGI ENKRIPSI & RLS
PostgreSQL Row Level Security (Supabase)

TARGET PENGGUNA
Owner, Akuntan, Kasir Toko, dan Auditor

PANDUAN DAN KEBIJAKAN MANAJEMEN USER LEVEL

SISTEM INFORMASI AKUNTANSI PERUSAHAAN DAGANG

Tata Kelola Hak Akses, Segregation of Duties (SoD), dan Implementasi Row Level Security (RLS)

---

1. PENDAHULUAN & LANDASAN TATA KELOLA

1.1 Latar Belakang

Dalam operasional perusahaan dagang, integritas data keuangan merupakan fondasi utama kelangsungan bisnis. Salah satu risiko terbesar dalam tata kelola keuangan adalah terjadinya penyalahgunaan wewenang (*fraud*), manipulasi angka penjualan, atau kelalaian pencatatan mutasi kas tanpa otorisasi yang sah.

Untuk menjamin keandalan data finansial, sistem akuntansi berbasis *Double-Entry Bookkeeping* ini menerapkan prinsip **Segregation of Duties (Pemisahan Tugas)** yang mengacu pada standar pengendalian internal **COSO (Committee of Sponsoring Organizations of the Treadway Commission)** dan **Standar Akuntansi Keuangan (SAK)** yang berlaku di Indonesia.

1.2 Prinsip Utama: Segregation of Duties (SoD)

Prinsip fundamental dari pemisahan tugas adalah:

> **"Orang yang memegang atau menerima uang fisik secara langsung (kasir/penjualan) tidak boleh menjadi orang yang sama yang memvalidasi pembukuan, mengubah bagan akun, atau menerbitkan laporan keuangan."**

Jika seluruh hak akses diberikan kepada satu orang tanpa pembatasan berjenjang, maka:

1. Kesalahan input (*human error*) tidak akan terdeteksi karena tidak ada proses verifikasi silang (*cross-check*).
2. Potensi kecurangan kas (*cash skimming* atau *lapping*) menjadi sangat besar karena pelaku dapat menghapus atau mengubah catatan pembukuan secara diam-diam.
3. Jejak audit (*audit trail*) menjadi tidak valid di hadapan auditor eksternal maupun otoritas perpajakan.

---

2. STRUKTUR 4 TINGKATAN PENGGUNA (4 USER LEVELS)

Berdasarkan analisis kebutuhan operasional perusahaan dagang (skala berkembang hingga menengah), sistem akuntansi ini mengadopsi **4 Tingkatan Pengguna (User Levels)** yang saling melengkapi dan memiliki batasan wewenang yang tegas:



2.1 LEVEL 1: OWNER / DIREKTUR (SUPERADMIN)

- **Deskripsi Peran:**
  Pemilik usaha, direktur utama, atau perwakilan pemegang saham yang memegang kendali tertinggi atas seluruh kebijakan operasional dan aset perusahaan.
- **Tanggung Jawab Utama:**
  1. Mengawasi kesehatan finansial perusahaan secara makro melalui Laporan Laba Rugi dan Neraca.
  2. Menentukan kebijakan struktur modal, dividen, dan pembagian laba (*retained earnings*).
  3. Mengelola akun staf (pemberian hak akses dan penonaktifan akun).
  4. Memberikan otorisasi akhir untuk pembatalan transaksi (*void*) dan penutupan buku (*period lock*).
- **Hak Akses Lengkap (Permissions):**
  - **Modul Transaksi:** Hak penuh membaca, menginput, dan mengevaluasi transaksi Kas Masuk, Kas Keluar, dan Jurnal Memorial.
  - **Modul Laporan:** Akses tak terbatas ke seluruh Laporan Keuangan (Buku Besar, Neraca Saldo, Laba Rugi, Neraca).
  - **Bagan Akun (Chart of Accounts):** Hak penuh menambah, mengubah, dan menonaktifkan kode akun, termasuk akun sensitif golongan Ekuitas (Modal Pemilik, Prive, Dividen).
  - **Manajemen Pengguna:** Menambah pengguna baru, mengatur role staf, dan mereset kredensial akses.
  - **Hak Khusus (Eksklusif):** Menghapus atau membatalkan transaksi yang keliru (*Void Transaction*) dan membuka/menutup periode buku akuntansi.

2.2 LEVEL 2: AKUNTAN SENIOR / ACCOUNTING SUPERVISOR

- **Deskripsi Peran:**
  Tenaga profesional di bidang keuangan yang bertugas menjaga ketepatan pembukuan, rekonsiliasi bank, dan penyusunan laporan keuangan berkala.
- **Tanggung Jawab Utama:**
  1. Memverifikasi seluruh bukti transaksi harian yang diinput oleh kasir.
  2. Melakukan pencatatan jurnal umum, jurnal penyesuaian (AJP), dan jurnal penutup akhir periode.
  3. Menyusun rekonsiliasi saldo kas/bank fisik dengan saldo catatan buku besar.
  4. Menerbitkan dan menganalisis laporan Laba Rugi dan Neraca untuk diserahkan kepada Owner.
- **Hak Akses Lengkap (Permissions):**
  - **Modul Transaksi:** Input dan mengelola Jurnal Memorial, Jurnal Penyesuaian, Kas Masuk, dan Kas Keluar.
  - **Modul Laporan:** Akses penuh untuk melihat dan mencetak Buku Besar, Neraca Saldo, Laba Rugi, dan Neraca.
  - **Bagan Akun:** Dapat menambah atau memperbarui akun operasional (Beban Operasional, Pendapatan, Aset Lancar, Utang Usaha).
- **Batasan Akses (Restrictions):**
  - ❌ Tidak dapat mengedit atau menghapus akun master Ekuitas/Modal tanpa izin Owner.
  - ❌ Tidak dapat menghapus transaksi berstatus `POSTED` secara permanen.
  - ❌ Tidak dapat menambah pengguna baru atau mengubah peran pengguna lain.

2.3 LEVEL 3: KASIR OPERASIONAL / STAF KEUANGAN TOKO

- **Deskripsi Peran:**
  Staf garda depan (*front-line staff*) yang bertugas mencatat transaksi penerimaan kas penjualan dan pengeluaran belanja operasional rutin toko.
- **Tanggung Jawab Utama:**
  1. Mencatat uang kas yang masuk dari penjualan barang dagang tunai atau pelunasan piutang pelanggan.
  2. Mencatat pengeluaran kas kecil (*petty cash*) untuk operasional harian (seperti ongkos kirim, perlengkapan toko, biaya bensin).
  3. Mencetak Bukti Kas Masuk (BKM) dan Bukti Kas Keluar (BKK) sebagai bukti fisik serah terima uang.
- **Hak Akses Lengkap (Permissions):**
  - **Kas Masuk:** Menginput nominal, tanggal, memilih akun kas tujuan, dan mencetak BKM.
  - **Kas Keluar:** Menginput nominal, tanggal, memilih akun beban/utang tujuan, dan mencetak BKK.
- **Batasan Ketat (Strict Restrictions):**
  - 🚫 **DILARANG KERAS** melihat Laporan Laba Rugi, Neraca, dan Buku Besar perusahaan (menjaga kerahasiaan profitabilitas bisnis).
  - 🚫 **DILARANG** menginput Jurnal Penyesuaian atau Jurnal Umum Memorial multi-baris.

- 🚫 **DILARANG** mengubah (*edit*) atau menghapus (*delete*) transaksi kas yang sudah disimpan ke sistem (mencegah manipulasi uang kas).
- 🚫 **DILARANG** menambah atau mengubah Bagan Akun (COA).

2.4 LEVEL 4: AUDITOR INDEPENDEN / KONSULTAN PAJAK

- **Deskripsi Peran:**
  Pihak eksternal (Kantor Akuntan Publik / Konsultan Pajak) atau auditor internal independen yang bertugas memeriksa kewajaran laporan keuangan dan kepatuhan perpajakan.
- **Tanggung Jawab Utama:**
  1. Menelusuri jejak audit (*audit trail*) dari saldo akhir laporan hingga ke bukti voucher asli.
  2. Melakukan pengujian substantif atas saldo kas, piutang, persediaan, dan utang dagang.
  3. Menguji kepatuhan penerapan prinsip *matching principle* antara pendapatan dan beban pokok penjualan (HPP).
- **Hak Akses Lengkap (Permissions):**
  - **Mode Baca Saja (Read-Only Total):** Dapat melihat seluruh ayat jurnal, mutasi buku besar, neraca saldo, laba rugi, dan neraca.
  - **Ekspor & Cetak:** Dapat mencetak dan mengekspor data laporan ke dalam format PDF/Excel untuk bahan pengujian audit.
- **Batasan Ketat (Strict Restrictions):**
  - 🚫 **SAMA SEKALI TIDAK MEMILIKI HAK TULIS (WRITE ACCESS)**: Tidak ada tombol tambah transaksi, edit, hapus, maupun ubah akun master.
  - 🚫 Tidak dapat mengakses pengaturan pengguna sistem.

---

3. MATRIKS OTORITAS & HAK AKSES SISTEM (MATRIX OF AUTHORITY)

Tabel berikut merupakan acuan baku matriks hak akses (*Access Control Matrix*) yang diterapkan pada sistem akuntansi:

Modul & Fungsi Sistem	Level 1: Owner	Level 2: Akuntan	Level 3: Kasir	Level 4: Auditor
Input Kas Masuk (BKM)	✅ Ya	✅ Ya	✅ Ya	👁 Hanya Lihat
Input Kas Keluar (BKK)	✅ Ya	✅ Ya	✅ Ya	👁 Hanya Lihat
Input Jurnal Memorial (AJP/Umum)	✅ Ya	✅ Ya	❌ Ditolak	👁 Hanya Lihat
Lihat Riwayat & Voucher Jurnal	✅ Ya	✅ Ya	👁 Transaksi Sendiri	✅ Ya
Buku Besar (General Ledger)	✅ Ya	✅ Ya	❌ Ditolak	👁 Hanya Lihat
Neraca Saldo (Trial Balance)	✅ Ya	✅ Ya	❌ Ditolak	👁 Hanya Lihat
Laporan Laba Rugi	✅ Ya	✅ Ya	❌ Ditolak	👁 Hanya Lihat
Laporan Neraca (Balance Sheet)	✅ Ya	✅ Ya	❌ Ditolak	👁 Hanya Lihat
Kelola Bagan Akun (Tambah/Edit Akun)	✅ Ya	✅ Ya (Operasional)	❌ Ditolak	👁 Hanya Lihat
Batalkan / Void Transaksi	✅ Ya (Eksklusif)	❌ Ditolak	❌ Ditolak	❌ Ditolak
Tutup Buku Periode (Period Lock)	✅ Ya (Eksklusif)	❌ Ditolak	❌ Ditolak	❌ Ditolak
Manajemen Pengguna (User Management)	✅ Ya	❌ Ditolak	❌ Ditolak	❌ Ditolak

Keterangan:

- ✅ **Ya:** Memiliki hak penuh membuat dan memproses data.
- 👁 **Hanya Lihat:** Hak akses baca (*read-only*) tanpa izin memodifikasi.
- ❌ **Ditolak:** Tidak memiliki akses ke modul tersebut (menu otomatis disembunyikan dan diblokir di database).

---

4. IMPLEMENTASI TEKNIS KEAMANAN DATABASE (SUPABASE POSTGRESQL)

Keamanan hak akses pada sistem ini tidak hanya dipasang pada antarmuka (UI), tetapi ditegakkan secara mutlak pada level mesin database PostgreSQL menggunakan **Row Level Security (RLS)**.

4.1 Definisi Role pada Database

Struktur role disimpan pada tabel `public.profiles` yang terhubung secara satu-ke-satu (*one-to-one*) dengan `auth.users` Supabase:

```
CREATE TABLE IF NOT EXISTS public.profiles (
    id UUID PRIMARY KEY REFERENCES auth.users(id) ON DELETE CASCADE,
    full_name TEXT NOT NULL,
    role TEXT NOT NULL DEFAULT 'accountant'
        CHECK (role IN ('owner', 'accountant', 'cashier', 'auditor')),
    avatar_url TEXT,
    created_at TIMESTAMPTZ NOT NULL DEFAULT timezone('utc'::text, now()),
    updated_at TIMESTAMPTZ NOT NULL DEFAULT timezone('utc'::text, now())
);
```

4.2 Helper Function Otoritas Sesi

Database menggunakan fungsi pembantu (*security definer function*) untuk membaca peran pengguna yang sedang aktif:

```
CREATE OR REPLACE FUNCTION public.current_user_role()
RETURNS TEXT AS $$
    SELECT role FROM public.profiles WHERE id = auth.uid();
$$ LANGUAGE sql STABLE SECURITY DEFINER;
```

4.3 Kebijakan Row Level Security (RLS)

1. **Kebijakan Input Jurnal Header (`journal_entries`):**

```
CREATE POLICY "Owner, Accountant, dan Cashier dapat membuat jurnal"
    ON public.journal_entries FOR INSERT
    TO authenticated
    WITH CHECK (public.current_user_role() IN ('owner', 'accountant', 'cashier'));
```

2. **Kebijakan Pembatasan Input Jurnal Baris (`journal_lines`):**
   Kasir hanya dapat mengisi baris jurnal yang bersumber dari form Kas Masuk atau Kas Keluar, sedangkan Jurnal Manual ditolak jika dipanggil di luar wewenang.
3. **Kebijakan Pembatalan / Hapus Transaksi:**

```
CREATE POLICY "Hanya Owner yang dapat menghapus transaksi"
    ON public.journal_entries FOR DELETE
    TO authenticated
    USING (public.current_user_role() = 'owner');
```

---

5. STANDAR OPERASIONAL PROSEDUR (SOP) PENGELOLAAN PENGGUNA

5.1 Prosedur Penambahan Staf Baru (Onboarding)

1. **Permohonan Akses:** Bagian SDM/Operasional mengajukan formulir penambahan staf baru beserta deskripsi tugasnya kepada Owner.
2. **Penetapan Level Akses:**
   - Jika staf bertugas di toko/kasir meja penjualan ➔ Ditetapkan sebagai `cashier`.
   - Jika staf bertugas menyusun laporan keuangan harian/pajak ➔ Ditetapkan sebagai `accountant`.
   - Jika staf adalah konsultan audit independen ➔ Ditetapkan sebagai `auditor`.
3. **Pendaftaran Akun:** Owner masuk ke dashboard Supabase (atau menu Manajemen Pengguna), mendaftarkan alamat email resmi staf, membuat kata sandi awal, dan menetapkan kolom `role` yang sesuai.
4. **Login Pertama:** Staf login ke aplikasi menggunakan kredensial tersebut dan diwajibkan mengganti kata sandi demi privasi.

5.2 Prosedur Penanganan Kesalahan Input Transaksi (Koreksi)

Jika seorang Kasir atau Akuntan melakukan kesalahan input:

1. **Kasir Dilarang Menghapus Data:** Kasir tidak memiliki akses hapus/edit. Kasir wajib segera melaporkan nomor bukti transaksi (`BKM-...` atau `BKK-...`) dan bukti fisik terkait kepada Akuntan/Owner.
2. **Metode Koreksi Standar (Jurnal Pembalik):**
   Akuntan membuat transaksi pembalik untuk menetralkan saldo akun yang salah catat, kemudian menginput kembali transaksi dengan nominal/akun yang benar. Hal ini memastikan riwayat pembukuan tetap transparan (*audit trail* terjaga).
3. **Metode Void (Pembatalan Langsung):**
   Hanya Owner yang berwenang menandai transaksi menjadi `VOID` atau menghapusnya jika transaksi terjadi dalam masa pengujian.

5.3 Prosedur Penonaktifan Akun Staf (Offboarding)

1. Ketika seorang staf mengundurkan diri atau dipindahtugaskan, akun staf tersebut wajib **segera dinonaktifkan dalam waktu maksimal 1×24 jam**.
2. Penonaktifan dilakukan melalui Supabase Auth dengan memilih opsi **"Disable User"** atau menghapus akun terkait.
3. Data seluruh transaksi historis yang pernah dibuat oleh staf tersebut di masa lalu **TIDAK AKAN HILANG** karena tabel relasi menerapkan aturan `ON DELETE SET NULL`, sehingga jejak audit masa lalu tetap utuh.

---

6. KESIMPULAN & REKOMENDASI TATA KELOLA

1. Penerapan **4 User Levels (Owner, Akuntan, Kasir, Auditor)** memberikan proteksi optimal terhadap keamanan finansial perusahaan dagang tanpa menghambat kelancaran operasional harian toko.

2. Kasir mendapatkan kecepatan dalam menginput transaksi kas tanpa beban teknis akuntansi yang rumit, sementara Akuntan dan Owner memiliki visibilitas penuh atas laporan laba rugi dan neraca.
3. Hak akses yang ditegakkan menggunakan **Row Level Security (RLS)** pada level PostgreSQL memastikan bahwa data perusahaan tetap aman sekalipun ada upaya akses langsung dari luar aplikasi.

Dokumen ini diterbitkan sebagai Standar Operasional Kebijakan Sistem Akuntansi Perusahaan Dagang.